

What is Insecure File Upload?

- When a website allows users to upload files without proper validation.
- Attackers upload malicious files (PHP shells, JS, malware).
- Leads to server takeover, data leak, remote code execution (RCE).

How Hackers Exploit Insecure File Upload

- Uploading web shells (shell.php).
- Renaming payloads to bypass filters (image.php.jpg).
- Spoofing MIME type to pretend file is an image.
- Null-byte trick to bypass extension checks.
- Overwriting important files like .htaccess.

Impact of Insecure File Upload

- Full server compromise.
- Remote Code Execution.
- Website defacement.
- Database theft.
- Malware distribution to users.
- Privilege escalation inside the server.

How to Prevent Insecure File Upload ⚡

- Allow only safe extensions (jpg/png/pdf).
- Validate file on server-side (not just client).
- Check MIME type + magic bytes.
- Rename every uploaded file (never trust user filename).
- Store files outside webroot.
- Block executable extensions (php, jsp, aspx, py).
- Scan uploads with antivirus.

What is Path Traversal?

- A vulnerability where attackers access restricted files/folders on the server.
- Using patterns like:
`../..../etc/passwd`

How Hackers Perform Path Traversal

- Manipulating file parameters:
`?file=../../config.php`
- URL encoding to bypass filters:
`..%2F..%2F`
- Double encoding:
`..%252F..%252F`
- Abusing download/view endpoints like:
`view.php?image=profile.jpg`

Impact of Path Traversal

- Reading sensitive files (/etc/passwd, config.php).
- Exposing environment variables, tokens, API keys.
- Accessing server logs → more attack vectors.
- Discovering database credentials.
- Full system compromise when combined with file uploads.

How to Prevent Path Traversal ⚡

- Never trust user-controlled file paths.
- Use whitelisted, fixed filenames.
- Normalize and sanitize file paths.
- Block ../ and encoded traversal sequences.
- Store sensitive files outside webroot.
- Use secure system file access functions.

**Why File Upload + Path Traversal
= Deadly Combo (RCE) **

- File upload allows attacker to place a malicious file on the server.
- Path traversal allows attacker to reach and execute that malicious file.
- Together → attacker can upload a .php shell and then execute it using traversal, resulting in: Remote Code Execution, Full server takeover & Root access.
- Complete system compromise
- This combination is one of the most dangerous attacks in web security.